# 常見之軟體與企業的安全威脅分析

果核數位
台灣 114 台北市內湖區瑞湖街111號

# About Me

## Experience

- 果核數位－資安研發部　副理
- 果核數位－軟體開發安全部　副理
- 資誠聯合會計師事務所－風險管理　顧問

## Expertise

- 風險管理與發規遵循
- 資安評估 /健診
- 網站滲透測試
- 軟體系統開發與流程調教
- 軟體系統安全架構規劃設計

## Certificate

- CISSP - Certified Information Systems Security Professional
- CSSLP - Certified Secure Software Lifecycle Professional
- ISO 27001:2022—Information Security Management Systems Auditor/ Lead Auditor
- CEH - EC-Council Certified Ethical Hacker
- Java EE 5 Web Component Developer, SCWCD
- Solutions Developer Web Applications, MCSD
- RHCVA - Red Hat Certified Virtualization Administrator, RHCVA
- Big Data Knowledge Today

© 2022 Proprietary and Confidential of Digicentre

# Previously Shared Topics

- 開發與資安的合作之路從互相理解開始
  Building Secure Software Starts with Effective Communication between Developers and Security Experts (18th Mar. , 2023)

- 企業安全開發面臨的挑戰
  Challenges of enterprises facing secure development (12th April. , 2023)

- 企業安全開發流程升級之路
  The Journey of Upgrading Enterprise Security Development Processes (9th May. , 2023)

- 稽核與被稽核的那些事
  A story of auditor and auditee (15th Sept. , 2023)

- 那些沒有被說出口的資安需求
  That security requirement we need to know (19th Oct. , 2023)

- DevOps + Sec 是強力援手還是搗亂者
  DevOps + Sec: Powerful Ally or Disruptive Force? (10th Jul. , 2024)

- DevSecOps 與 AI：雙面刃的挑戰與機遇
  DevSecOps and AI: Mastering the Dual-Threat of Challenges and Opportunities (30th Aug. , 2024)

© 2024 Proprietary and Confidential of Digicentre

# Agenda

1. 威脅建模
2. 企業架構
3. 軟體架構
4. 威脅邊界

© 2024 Proprietary and Confidential of Digicentre

01

# 威脅建模

© 2024 Proprietary and Confidential of Digicentre

# 威脅建模方法與流程（1/2）

- 1. 識別資源與元件
  - 確定資產 (assets)
  - 參與者 (actors)
  - 入口點 (entry points)
  - 元件 (component)
  - 使用案例(use case)
  - 信任級別 (trust level)

© 2024 Proprietary and Confidential of Digicentre

# 威脅建模方法與流程 ( 2 / 2 )

- 2. 發掘威脅並製表 ( Threat Model Methodology)
  - LINDDUN
  - PASTA
  - STRIDE
  - OCTAVE
  - ASVS
- 3. 對每一項威脅設計緩解措施，可包含安全控制實現。
- 4. 透過創建風險矩陣 (risk matrix) 判斷威脅是否已充分緩解。

© 2024 Proprietary and Confidential of Digicentre

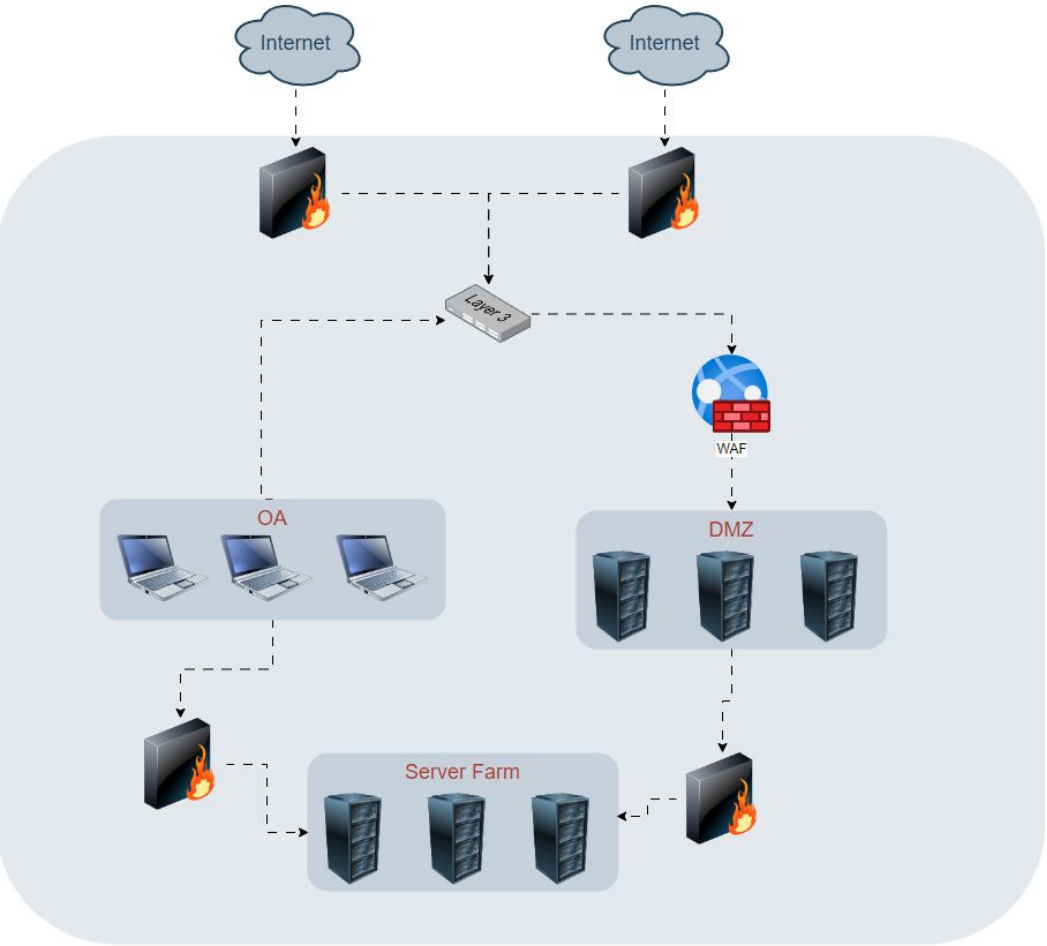
02

# 企業架構

© 2024 Proprietary and Confidential of Digicentre

# 企業網路架構基本

- 單點衝擊
- 釣魚信件攻擊
- USB 惡意程式
- 惡意程式
- VPN
- 應用系統漏洞




© 2024 Proprietary and Confidential of Digicentre

03

# 軟體架構

© 2024 Proprietary and Confidential of Digicentre

# Application Security Verification Standard, ASVS

- Architecture, Design and Threat Modeling
- Authentication
- Session Management
- Access Control

---

- Validation, Sanitization and Encoding
- Stored Cryptography
- Error Handling and Logging
- Data Protection

---

- Communication
- Malicious Code
- Business Logic
- Files and Resources
- API and Web Service
- Configuration

https://owasp.org/www-project-application-security-verification-standard/

© 2024 Proprietary and Confidential of Digicentre

# Application Security Verification Standard, ASVS

**Using the ASVS** ..... **11**

*Application Security Verification Levels* ..... *11*

*How to use this standard* ..... *12*

Level 1 - First steps, automated, or whole of portfolio view ..... 12

Level 2 - Most applications ..... 12

Level 3 - High value, high assurance, or high safety ..... 12

*Applying ASVS in Practice* ..... *13*

*How to Reference ASVS Requirements* ..... *13*

© 2024 Proprietary and Confidential of Digicentre

# Application Security Verification Standard, ASVS

**Using the ASVS** ..... **11**

*Application Security Verification Levels* ..... *11*

*How to use this standard* ..... *12*

Level 1 - First steps, automated, or whole of portfolio view ..... 12

Level 2 - Most applications ..... 12

Level 3 - High value, high assurance, or high safety ..... 12

*Applying ASVS in Practice* ..... *13*

*How to Reference ASVS Requirements* ..... *13*

© 2024 Proprietary and Confidential of Digicentre

# Application Security Verification Standard, ASVS

## Level 1 - First steps, automated, or whole of portfolio view

An application achieves ASVS Level 1 if it adequately defends against application security vulnerabilities that are easy to discover, and included in the OWASP Top 10 and other similar checklists.

Level 1 is the bare minimum that all applications should strive for. It is also useful as a first step in a multi-phase effort or when applications do not store or handle sensitive data and therefore do not need the more rigorous controls of Level 2 or 3. Level 1 controls can be checked either automatically by tools or simply manually without access to source code. We consider Level 1 the minimum required for all applications.

Threats to the application will most likely be from attackers who are using simple and low effort techniques to identify easy-to-find and easy-to-exploit vulnerabilities. This is in contrast to a determined attacker who will spend focused energy to specifically target the application. If data processed by your application has high value, you would rarely want to stop at a Level 1 review.

© 2024 Proprietary and Confidential of Digicentre

# Application Security Verification Standard, ASVS

## Level 2 - Most applications

An application achieves ASVS Level 2 (or Standard) if it adequately defends against most of the risks associated with software today.

Level 2 ensures that security controls are in place, effective, and used within the application. Level 2 is typically appropriate for applications that handle significant business-to-business transactions, including those that process healthcare information, implement business-critical or sensitive functions, or process other sensitive assets, or industries where integrity is a critical facet to protect their business, such as the game industry to thwart cheaters and game hacks.

Threats to Level 2 applications will typically be skilled and motivated attackers focusing on specific targets using tools and techniques that are highly practiced and effective at discovering and exploiting weaknesses within applications.

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Session Management

| # | Description | L1 | L2 | L3 | CWE | NIST § |
|---|---|---|---|---|---|---|
| **3.4.1** | Verify that cookie-based session tokens have the 'Secure' attribute set. (C6) | ✓ | ✓ | ✓ | 614 | 7.1.1 |
| **3.4.2** | Verify that cookie-based session tokens have the 'HttpOnly' attribute set. (C6) | ✓ | ✓ | ✓ | 1004 | 7.1.1 |
| **3.4.3** | Verify that cookie-based session tokens utilize the 'SameSite' attribute to limit exposure to cross-site request forgery attacks. (C6) | ✓ | ✓ | ✓ | 16 | 7.1.1 |
| **3.4.4** | Verify that cookie-based session tokens use the "__Host-" prefix so cookies are only sent to the host that initially set the cookie. | ✓ | ✓ | ✓ | 16 | 7.1.1 |
| **3.4.5** | Verify that if the application is published under a domain name with other applications that set or use session cookies that might disclose the session cookies, set the path attribute in cookie-based session tokens using the most precise path possible. (C6) | ✓ | ✓ | ✓ | 16 | 7.1.1 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Memory, String, and Unmanaged Code

## V5.4 Memory, String, and Unmanaged Code

The following requirements will only apply when the application uses a systems language or unmanaged code.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **5.4.1** | Verify that the application uses memory-safe string, safer memory copy and pointer arithmetic to detect or prevent stack, buffer, or heap overflows. | | ✓ | ✓ | 120 |
| **5.4.2** | Verify that format strings do not take potentially hostile input, and are constant. | | ✓ | ✓ | 134 |
| **5.4.3** | Verify that sign, range, and input validation techniques are used to prevent integer overflows. | | ✓ | ✓ | 190 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Input Validation

## V5.1 Input Validation

Properly implemented input validation controls, using positive allow lists and strong data typing, can eliminate more than 90% of all injection attacks. Length and range checks can reduce this further. Building in secure input validation is required during application architecture, design sprints, coding, and unit and integration testing. Although many of these items cannot be found in penetration tests, the results of not implementing them are usually found in V5.3 - Output encoding and Injection Prevention Requirements. Developers and secure code reviewers are recommended to treat this section as if L1 is required for all items to prevent injections.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **5.1.1** | Verify that the application has defenses against HTTP parameter pollution attacks, particularly if the application framework makes no distinction about the source of request parameters (GET, POST, cookies, headers, or environment variables). | ✓ | ✓ | ✓ | 235 |
| **5.1.2** | Verify that frameworks protect against mass parameter assignment attacks, or that the application has countermeasures to protect against unsafe parameter assignment, such as marking fields private or similar. (C5) | ✓ | ✓ | ✓ | 915 |
| **5.1.3** | Verify that all input (HTML form fields, REST requests, URL parameters, HTTP headers, cookies, batch files, RSS feeds, etc) is validated using positive validation (allow lists). (C5) | ✓ | ✓ | ✓ | 20 |
| **5.1.4** | Verify that structured data is strongly typed and validated against a defined schema including allowed characters, length and pattern (e.g. credit card numbers, e-mail addresses, telephone numbers, or validating that two related fields are reasonable, such as checking that suburb and zip/postcode match). (C5) | ✓ | ✓ | ✓ | 20 |
| **5.1.5** | Verify that URL redirects and forwards only allow destinations which appear on an allow list, or show a warning when redirecting to potentially untrusted content. | ✓ | ✓ | ✓ | 601 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Input Validation

## V5.2 Sanitization and Sandboxing

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **5.2.1** | Verify that all untrusted HTML input from WYSIWYG editors or similar is properly sanitized with an HTML sanitizer library or framework feature. (C5) | ✓ | ✓ | ✓ | 116 |
| **5.2.2** | Verify that unstructured data is sanitized to enforce safety measures such as allowed characters and length. | ✓ | ✓ | ✓ | 138 |
| **5.2.3** | Verify that the application sanitizes user input before passing to mail systems to protect against SMTP or IMAP injection. | ✓ | ✓ | ✓ | 147 |
| **5.2.4** | Verify that the application avoids the use of eval() or other dynamic code execution features. Where there is no alternative, any user input being included must be sanitized or sandboxed before being executed. | ✓ | ✓ | ✓ | 95 |
| **5.2.5** | Verify that the application protects against template injection attacks by ensuring that any user input being included is sanitized or sandboxed. | ✓ | ✓ | ✓ | 94 |
| **5.2.6** | Verify that the application protects against SSRF attacks, by validating or sanitizing untrusted data or HTTP file metadata, such as filenames and URL input fields, and uses allow lists of protocols, domains, paths and ports. | ✓ | ✓ | ✓ | 918 |
| **5.2.7** | Verify that the application sanitizes, disables, or sandboxes user-supplied Scalable Vector Graphics (SVG) scriptable content, especially as they relate to XSS resulting from inline scripts, and foreignObject. | ✓ | ✓ | ✓ | 159 |
| **5.2.8** | Verify that the application sanitizes, disables, or sandboxes user-supplied scriptable or expression template language content, such as Markdown, CSS or XSL stylesheets, BBCode, or similar. | ✓ | ✓ | ✓ | 94 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Stored Cryptography

## V6 Stored Cryptography

### Control Objective

Ensure that a verified application satisfies the following high level requirements:

- All cryptographic modules fail in a secure manner and that errors are handled correctly.
- A suitable random number generator is used.
- Access to keys is securely managed.

### V6.1 Data Classification

The most important asset is the data processed, stored or transmitted by an application. Always perform a privacy impact assessment to classify the data protection needs of any stored data correctly.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **6.1.1** | Verify that regulated private data is stored encrypted while at rest, such as Personally Identifiable Information (PII), sensitive personal information, or data assessed likely to be subject to EU's GDPR. | | ✓ | ✓ | 311 |
| **6.1.2** | Verify that regulated health data is stored encrypted while at rest, such as medical records, medical device details, or de-anonymized research records. | | ✓ | ✓ | 311 |
| **6.1.3** | Verify that regulated financial data is stored encrypted while at rest, such as financial accounts, defaults or credit history, tax records, pay history, beneficiaries, or de-anonymized market or research records. | | ✓ | ✓ | 311 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Algorithms

## V6.2 Algorithms

Recent advances in cryptography mean that previously safe algorithms and key lengths are no longer safe or sufficient to protect data. Therefore, it should be possible to change algorithms.

Although this section is not easily penetration tested, developers should consider this entire section as mandatory even though L1 is missing from most of the items.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **6.2.1** | Verify that all cryptographic modules fail securely, and errors are handled in a way that does not enable Padding Oracle attacks. | ✓ | ✓ | ✓ | 310 |
| **6.2.2** | Verify that industry proven or government approved cryptographic algorithms, modes, and libraries are used, instead of custom coded cryptography. (C8) | | ✓ | ✓ | 327 |
| **6.2.3** | Verify that encryption initialization vector, cipher configuration, and block modes are configured securely using the latest advice. | | ✓ | ✓ | 326 |
| **6.2.4** | Verify that random number, encryption or hashing algorithms, key lengths, rounds, ciphers or modes, can be reconfigured, upgraded, or swapped at any time, to protect against cryptographic breaks. (C8) | | ✓ | ✓ | 326 |
| **6.2.5** | Verify that known insecure block modes (i.e. ECB, etc.), padding modes (i.e. PKCS#1 v1.5, etc.), ciphers with small block sizes (i.e. Triple-DES, Blowfish, etc.), and weak hashing algorithms (i.e. MD5, SHA1, etc.) are not used unless required for backwards compatibility. | | ✓ | ✓ | 326 |

# ASVS : Algorithms

## V6.3 Random Values

True Pseudo-random Number Generation (PRNG) is incredibly difficult to get right. Generally, good sources of entropy within a system will be quickly depleted if over-used, but sources with less randomness can lead to predictable keys and secrets.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **6.3.1** | Verify that all random numbers, random file names, random GUIDs, and random strings are generated using the cryptographic module's approved cryptographically secure random number generator when these random values are intended to be not guessable by an attacker. | | ✓ | ✓ | 338 |
| **6.3.2** | Verify that random GUIDs are created using the GUID v4 algorithm, and a Cryptographically-secure Pseudo-random Number Generator (CSPRNG). GUIDs created using other pseudo-random number generators may be predictable. | | ✓ | ✓ | 338 |
| **6.3.3** | Verify that random numbers are created with proper entropy even when the application is under heavy load, or that the application degrades gracefully in such circumstances. | | | ✓ | 338 |

© 20

# ASVS : Secret Management

## V6.4 Secret Management

Although this section is not easily penetration tested, developers should consider this entire section as mandatory even though L1 is missing from most of the items.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **6.4.1** | Verify that a secrets management solution such as a key vault is used to securely create, store, control access to and destroy secrets. (C8) | | ✓ | ✓ | 798 |
| **6.4.2** | Verify that key material is not exposed to the application but instead uses an isolated security module like a vault for cryptographic operations. (C8) | | ✓ | ✓ | 320 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Log Content

## V7.1 Log Content

Logging sensitive information is dangerous - the logs become classified themselves, which means they need to be encrypted, become subject to retention policies, and must be disclosed in security audits. Ensure only necessary information is kept in logs, and certainly no payment, credentials (including session tokens), sensitive or personally identifiable information.

V7.1 covers OWASP Top 10 2017:A10. As 2017:A10 and this section are not penetration testable, it's important for:

- Developers to ensure full compliance with this section, as if all items were marked as L1
- Penetration testers to validate full compliance of all items in V7.1 via interview, screenshots, or assertion

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **7.1.1** | Verify that the application does not log credentials or payment details. Session tokens should only be stored in logs in an irreversible, hashed form. (C9, C10) | ✓ | ✓ | ✓ | 532 |
| **7.1.2** | Verify that the application does not log other sensitive data as defined under local privacy laws or relevant security policy. (C9) | ✓ | ✓ | ✓ | 532 |
| **7.1.3** | Verify that the application logs security relevant events including successful and failed authentication events, access control failures, deserialization failures and input validation failures. (C5, C7) | | ✓ | ✓ | 778 |
| **7.1.4** | Verify that each log event includes necessary information that would allow for a detailed investigation of the timeline when an event happens. (C9) | | ✓ | ✓ | 778 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Log Content

## V7.1 Log Content

Logging sensitive information is dangerous - the logs become classified themselves, which means they need to be encrypted, become subject to retention policies, and must be disclosed in security audits. Ensure only necessary information is kept in logs, and certainly no payment, credentials (including session tokens), sensitive or personally identifiable information.

V7.1 covers OWASP Top 10 2017:A10. As 2017:A10 and this section are not penetration testable, it's important for:

- Developers to ensure full compliance with this section, as if all items were marked as L1
- Penetration testers to validate full compliance of all items in V7.1 via interview, screenshots, or assertion

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **7.1.1** | Verify that the application does not log credentials or payment details. Session tokens should only be stored in logs in an irreversible, hashed form. (C9, C10) | ✓ | ✓ | ✓ | 532 |
| **7.1.2** | Verify that the application does not log other sensitive data as defined under local privacy laws or relevant security policy. (C9) | ✓ | ✓ | ✓ | 532 |
| **7.1.3** | Verify that the application logs security relevant events including successful and failed authentication events, access control failures, deserialization failures and input validation failures. (C5, C7) | | ✓ | ✓ | 778 |
| **7.1.4** | Verify that each log event includes necessary information that would allow for a detailed investigation of the timeline when an event happens. (C9) | | ✓ | ✓ | 778 |

© 2024 Proprietary and Confidential of Digicentre

# ASVS : Log Content

## V7.3 Log Protection

Logs that can be trivially modified or deleted are useless for investigations and prosecutions. Disclosure of logs can expose inner details about the application or the data it contains. Care must be taken when protecting logs from unauthorized disclosure, modification or deletion.

| # | Description | L1 | L2 | L3 | CWE |
|---|---|---|---|---|---|
| **7.3.1** | Verify that all logging components appropriately encode data to prevent log injection. (C9) | | ✓ | ✓ | 117 |
| **7.3.2** | [DELETED, DUPLICATE OF 7.3.1] | | | | |
| **7.3.3** | Verify that security logs are protected from unauthorized access and modification. (C9) | | ✓ | ✓ | 200 |
| **7.3.4** | Verify that time sources are synchronized to the correct time and time zone. Strongly consider logging only in UTC if systems are global to assist with post-incident forensic analysis. (C9) | | ✓ | ✓ | |

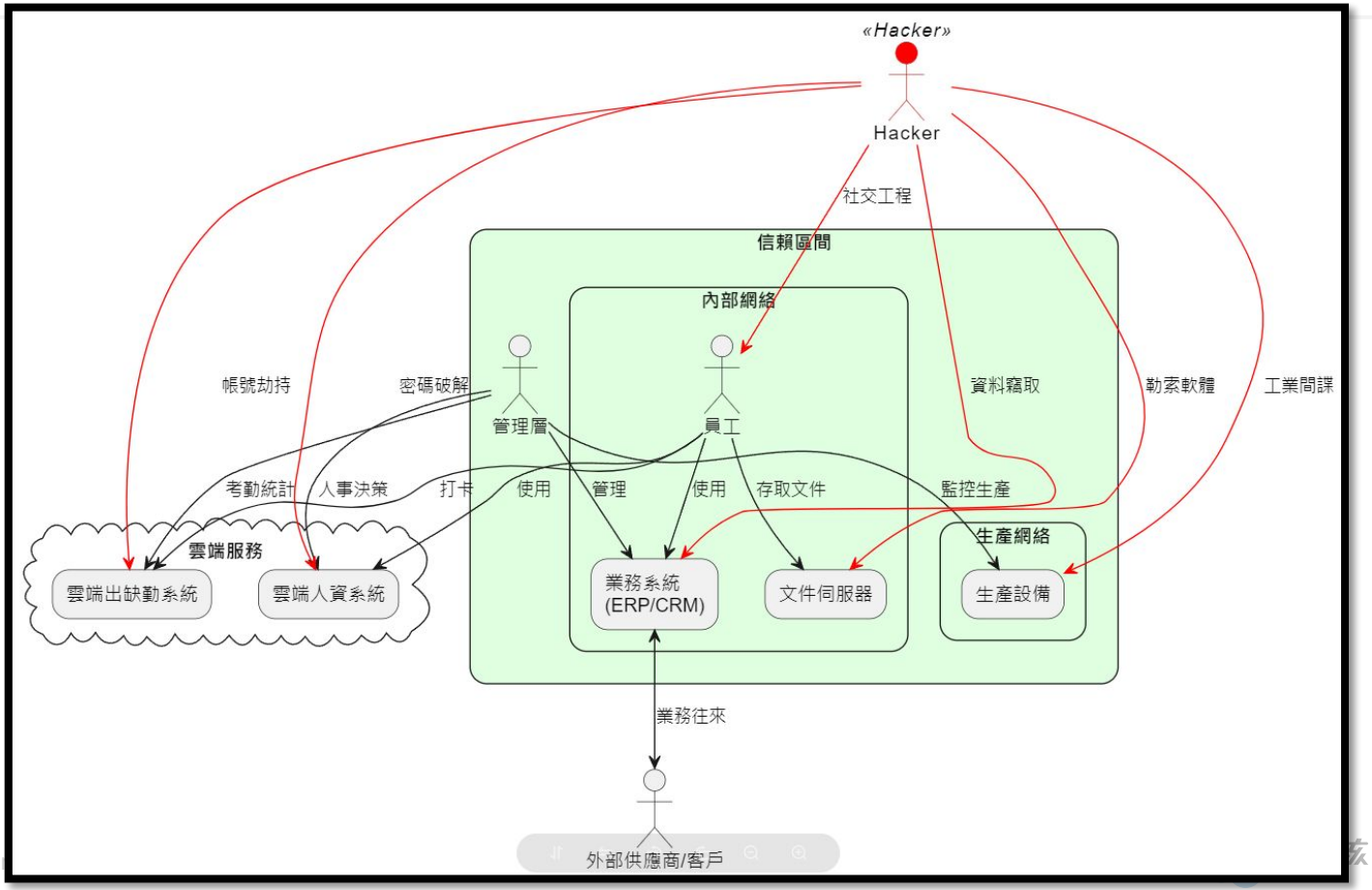
© 2024 Proprietary and Confidential of Digicentre

04

# 威脅邊界

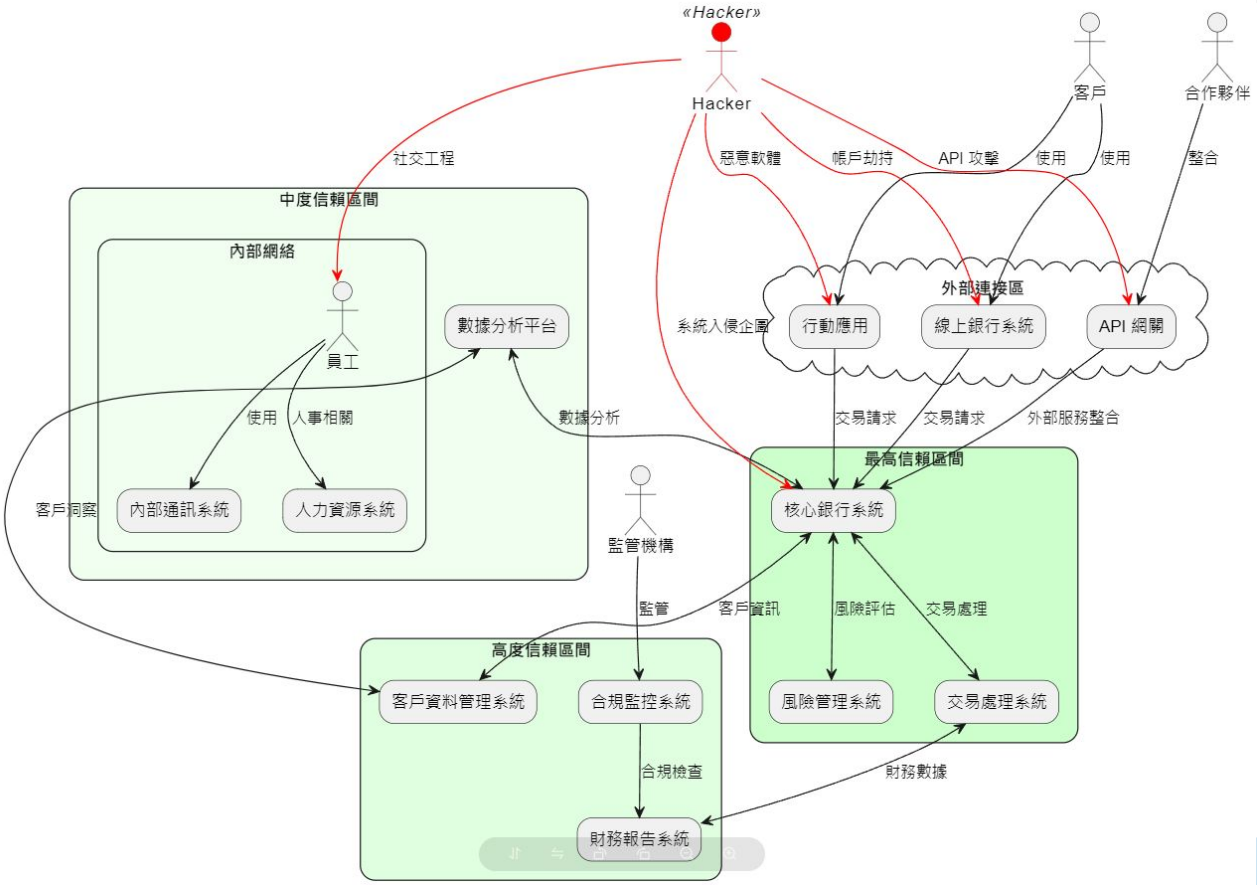
© 2024 Proprietary and Confidential of Digicentre

# 小型製造業為例




© 2024 Proprietary a

# 中大型金融業為例




© 2024 Proprietary anc

# Takeaway

- 企業可規劃適合的企業威脅邊界
- 應用系統可於企業底下建立屬於自己的威脅模型
- 可參考威脅建模方法論搭配OWASP ASVS

© 2024 Proprietary and Confidential of Digicentre

# Thank you